Vendor Management Policy

1. Purpose

The purpose of this document is to define the Cybersecurity Supply Chain Risk Management (C-SCRM) Policy for MBTA which will ensure the organization to identify, assess, and mitigate supply chain risk throughout the vendor lifecycle and is issued under the authority of Information Security Officer (ISO) of MBTA, effective as of March 17, 2026.

2. Scope

The policy applies to all vendors, contractors, service providers and third parties that:

- Access, process, and store MBTA data, including Personally Identifiable Information (PII) of riders, employees, or the public.
- Provide, operate, and maintain technology systems, Operational Technology (OT), or networks used by MBTA.
- Have logical and physical access to MBTA infrastructure, or facilities.
- Deliver components integrated into MBTA systems.
- Provide cloud services or professional services to MBTA.

3. Policy Statement

3.1 Supplier Inventory

All vendors associated with MBTA must be registered in the MBTA Vendor Inventory upon onboarding, by Vendor Management team, including but not limited to: Vendor name, Business Requirement, Criticality Risk Ranking, Point of Contact, and data types.

3.2 Risk Assessment

- Risk Assessments will be conducted when a new vendor is onboarded, periodically based on Criticality Tier, or when a security incident occurs.

- The tiers are divided into 4 types: Critical, High, Medium and Low tier which will be assessed for residual risk every 12, 18, 24 months and at onboarding only, respectively.

- Critical, High tier will be assessed for inherent risk every 12 months and Medium and Low tiers will be assessed for inherent risk every 24 months.

- The assessments will be conducted by the Vendor management team where inherent risk questionnaire must be completed by the Risk owner and residual risk questionnaire must be completed by the vendor.

- The findings are documented in Risk Register in MBTA Vendor inventory. The Risk acceptance, transfer or mitigation decision rests with the Risk owner along with feedback from Vendor Management team. The team must make a decision before contract execution.

- Critical and High Risk findings must be assessed and decision must be made within 6 weeks of findings. If not, the vendor shall be suspended for services provided. Medium Risk finding must be assessed and decision must be made within 6 months of findings. If not, vendor access must be suspended until resolved.

3.3 Contract Requirements

All vendor contracts must include a Security Addendum covering

- Certifications including SOC 2 Type II, SIG/ SIG Lite or CAIQ, Penetration Testing report (for SaaS vendors) for Critical and High Tier and SOC 2 Type II, ISO 27001 for Medium and Low Tier.
- Cybersecurity Awareness Training must be completed by vendor personnel with MBTA system access annually.
- Vendors must notify the Information Security team within 48 hours of discovering a security breach.
- MBTA reserves the right to audit the vendor annually with reasonable advance notice.
- Vendors must disclose all sub-suppliers to MBTA and ensure they are assessed for security risk.
- Data must be returned or certified destroyed within 3 weeks of contract termination.
- MBTA reserves the right to terminate vendor contract on vendor failure to remediate critical finding.

3.4 Vendor Access Controls

All vendor access to MBTA systems must:

- Authenticate and access the systems using multi-factor authentication
- Be limited to only the systems and data required for their contracted scope.
- Have all access logs retained for 12 months
- Be removed within 48 hours of contract termination.

3.5 Ongoing Monitoring

MBTA must conduct ongoing monitoring of vendor security posture:

Tier	Ongoing monitoring Frequency
Critical	Every 12 months
High	Every 18 months
Medium	Every 24 months
Low	Not required

An off-cycle review must be initiated within 10 days when a vendor is affected by a breach, acquired by a foreign entity, a critical vulnerability is discovered, or TSA security directive update affects the vendor.

3.6 Enforcement

Non-compliance with this policy by MBTA personnel may result in termination, in accordance with MBTA HR policies.

Vendors who fail to comply with Security Addendum requirements may face consequences including contract termination.

Exceptions to this policy must be requested by MBTA personnel, approved by ISO and may not exceed 6-12 months.

4. Roles and Responsibilities

Vendor Management Team

- Manages MBTA Vendor Inventory including onboarding vendor, conducting inherent and residual risk assessments and off-boarding.
- Consults the Risk Owner for Risk acceptance, transfer, or mitigation.
- Enforces the Security Addendum requirements throughout the vendor lifecycle.

Information Security Officer

- Coordinate incident response upon receiving vendor breach notification.
- Oversee vendor management program.

Risk Owner

- Own the risk associated with vendor products and services for their business unit
- Complete risk assessments for vendor product/service.

5. Definitions

- C-SCRM – Cybersecurity Supply Chain Risk Management: a framework to identify, assess, and mitigate cybersecurity risks introduced through third party vendor relationships.
- Vendor / Supplier – external organization providing products, services, or components to MBTA.
- Criticality Tier – the division of risks based on data access and operational impact
- Inherent Risk – risk assessed and found at the start of service
- Residual Risk – risk assessed and found after security controls are applied
- PII – Personally Identifiable Information such as SSN, Date of Birth of Massachusetts residents

6. Revision and Maintenance

The ISO shall ensure the policy is reviewed and updated annually or within 60 days of any supply chain security incident. All revisions must be approved by Chief Information Office (CIO) and documented in the Revision History table.

6.1. Revision History

Date	Description of Change	Reviewer
03/17/2026	V1	Utkarsha S - CIO